המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 05/10/2025 שעת הבחינה: 15:00
שנה"ל: תשפ"ה סמסטר: קיץ מועד: א'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 15:20, 15:50. לזכאי תוספת זמן גם בשעה 16:20

נא **לא לשאול** את השאלות הבאות בעזרת פתקים, כי לא יינתן עליהם מענה:
- יש טעות בבחינה/בשאלה/בסעיף...
- יש יותר מתשובה אחת נכונה או אף אחת מהתשובות לא נכונה.
- לא למדנו על...
- מה התרגום של [משהו] בעברית/באנגלית...
- מה המשמעות של ראשי התיבות...
- כל שאלה שעיקרה לגרום לגילוי התשובה

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)

- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, התשובה הנכונה היא סעיף א

<u>שאלה מספר 1:</u>

איזו תכונה חתימות דיגיטליות מאפשרות ש Message Authentication Codes לא מאפשרות?

א. אי-יכולת הכחשה

ב. סודיות

ג. אמינות המידע

ד. אותנטיות

<u>שאלה מספר 2:</u>

ב TLS, ה pre master secret מוצפן לפני העברתו אל השרת על ידי:

א. המפתח הפומבי של השרת

ב. המפתח הפרטי של השרת

ג. המפתח הפומבי של הלקוח

ד. המפתח הפרטי של הלקוח

<u>שאלה מספר 3:</u>

איזה מהתיאורים הבאים מתאר את התקפת ARP poisoning?

א. תוקף שולח הודעות ARP שקריות בהן הוא משקר לגבי מיפוי בין כתובת MAC ו IP, כדי שהתעבורה של הקורבן תגיע אליו (אל התוקף).

ב. תוקף שולח הודעות ARP רבות אל ה switch כדי להציף את הטבלה של ה switch במיפויים שקריים.

ג. תוקף מאזין לתעבורת ARP ומזהה הודעות ARP פגיעות, ומחלץ מהן את כתובת ה IP של הקורבנות.

ד. תוקף שולח הודעות ARP אל שרת ה DNS המקומי של הרשת, כדי ששרת ה DNS יעבוד כמו hub במקום כמו switch.

<u>שאלה מספר 4:</u>

איזה מהתרחישים הבאים ייחסמו על ידי מנגנון ה Same Origin Policy?

א. סקריפט שהגיע מ foo.com (זה ה origin של הסקריפט) מנסה לקרוא תוכן של תשובת http שמגיעה מ bar.com

ב. עמוד שהגיע מ foo.com מנסה לטעון תמונה מהדומיין bar.com

ג. סקריפט זדוני שהוחדר לעמוד שהגיע מ foo.com ושולח את פרטי הcookie של הקורבן אל bar.com

ד. משתמש גלש לאתר foo.com ובאתר זה ישנו סקריפט ששולח טופס אל הדומיין bar.com שאליו המשתמש מחובר (ולכן הדפדפן צירף את ה cookie של המשתמש לבקשה)

<u>שאלה מספר 5:</u>

אליס פיתחה קליינט ביטקוין "רזה", כלומר, הקליינט שפיתחה שומר רק את רשימת העסקאות שנכללות בבלוקצ'יין אבל עדיין לא בוזבזו ורק את הבלוק האחרון בבלוקצ'יין. איזו מבין הטענות הבאות נכונה?

א. הקליינט הזה לא יכול להתמודד בעצמו עם forkים מסויימים.

ב. הקליינט הזה שומר יותר מידע ממה ש miner שומר.

ג. הקליינט הזה לא יכול לוודא את ה proof of work של בלוק חדש שמוצג בפניו.

ד. הקליינט הזה לא יכול להיות בשימוש, כי אינו קליינט רשמי שאושר על ידי ביטקוין.

<u>שאלה מספר 6:</u>

אליס ובוב מעוניינים לדבר אחד עם השניה בצורה מאובטחת, כך שרק הם ידעו מה הם שולחים ביניהם.

אליס ובוב יצרו לעצמם (כל אחד בנפרד), מפתח פומבי ומפתח פרטי. אליס ובוב אינם יודעים את המפתחות אחד של השני, גם לא את הפומביים.

הם משתמשים בשירות מסרים, ולשירות זה יש שרת שיודע את המפתחות הפומביים האמיתיים של כל הלקוחות, כולל של אליס ובוב. השרת הינו תקין ואינו בשליטת תוקף.

אליס פונה אל השרת ומבקשת את המפתח הפומבי של בוב.

השרת שולח לה בחזרה: את המפתח הפומבי של בוב, את התאריך והשעה הנוכחיים, וחתימה דיגיטלית על הערכים הללו (מפתח פומבי ותאריך ושעה) שנחתמה על ידי המפתח הפרטי של השרת (כל הלקוחות יודעים את המפתח הפומבי האמיתי של השרת).

האם הפרוטוקול הנ"ל בטוח?

א. לא, תוקף MitM יכול לגרום לאליס לחשוב שהמפתח של התוקף זה המפתח של בוב.

ב. לא, תוקף off-path יכול לגרום לשרת לחשוב שהמפתח של בוב זה המפתח של אליס.

ג. לא, תוקף eavesdropper יכול לגרום לשרת לחשוב שהמפתח של בוב זה המפתח של אליס.

ד. כן, שום תוקף לא יכול לנצל לרעה את הפרוטוקול בזכות השימוש המתואר בחתימה דיגיטלית.

<u>שאלה מספר 7:</u>

איזה מבין הטענות הבאות נכונה בהקשר של Certificate Transparency (CT)?

א. CT מוסיף יומן ציבורי שבעזרתו ניתן לזהות הנפקת תעודות שגויות או זדוניות על ידי CAים.

ב. CT מבטל את הצורך ב CRL ו-OCSP על ידי חסימת כל תעודה שפג תוקפה באופן אוטומטי.

ג. CT מחליף את פרוטוקול TLS.

ד. CT מאפשר לדפדפן לאמת את זהות השרת ללא צורך בשרשרת אמון.

<u>שאלה מספר 8:</u>

מה מבין הבאים היא ההגדרה של תכונת ה pre image resistance?

א. Given a digest d of a random message, it is hard to find a message m s.t. d = h(m)

ב. Given a random message m_0, it is hard to find a message m_1 that is not equal to m_0 s.t. $h(m_0) = h(m_1)$

ג. It is hard to find messages $m_0 \neq m_1$ s.t. $h(m_0) = h(m_1)$

ד. It is hard to find messages $m_0 \neq m_1$ s.t. $h(m_0) \neq h(m_1)$

<u>שאלה מספר 9:</u>

איזה מנגנון מאפשר לשרת להגיד לדפדפן אלו משאבים מותר לדפדפן לטעון/להריץ בהקשר של העמוד הנוכחי?

א. CSP

ב. One time pad

ג. XSS

ד. CSRF

<u>שאלה מספר 10:</u>

מה מהבאים הינו אלגוריתם הצפנה (ופענוח) סימטרי?

א. AES

ב. RSA

ג. HSTS

ד. CT

--- סוף המבחן ---